

취약점 관리의 기초

취약점의 개념, CIA 삼요소, 그리고 취약점 관리 수명 주기를 이해하는 것은 효과적인 정보 보안의 출발점입니다.



CIA 삼요소와 취약점

기밀성

누가 데이터에 접근할 수 있는지 — 정보 유출 취약점이 이 요소에 영향을 미칩니다.

무결성

누가 데이터를 수정할 수 있는지 — 권한 없는 수정을 허용하는 취약점이 해당됩니다.

가용성

권한 있는 사용자가 접근할 수 있는지 — DoS 취약점이 이 요소를 위협합니다.

취약점이란 공격자가 보안에 영향을 미치는 방식으로 악용할 수 있는 정보 시스템의 약점입니다. 버그, 코드 논리 결함, 설계 결함에서 비롯됩니다.



취약점의 주요 유형

1

서비스 거부 (DoS)

가용성을 위협 – 권한 있는 사용자가 시스템에 접근하지 못하도록 차단합니다.

2

정보 유출

기밀성을 위협 – 권한 없는 사용자가 접근할 수 없는 데이터를 읽을 수 있게 합니다.

3

정보 수정

무결성을 위협 – 권한 없는 사용자가 데이터를 변경할 수 있게 합니다.

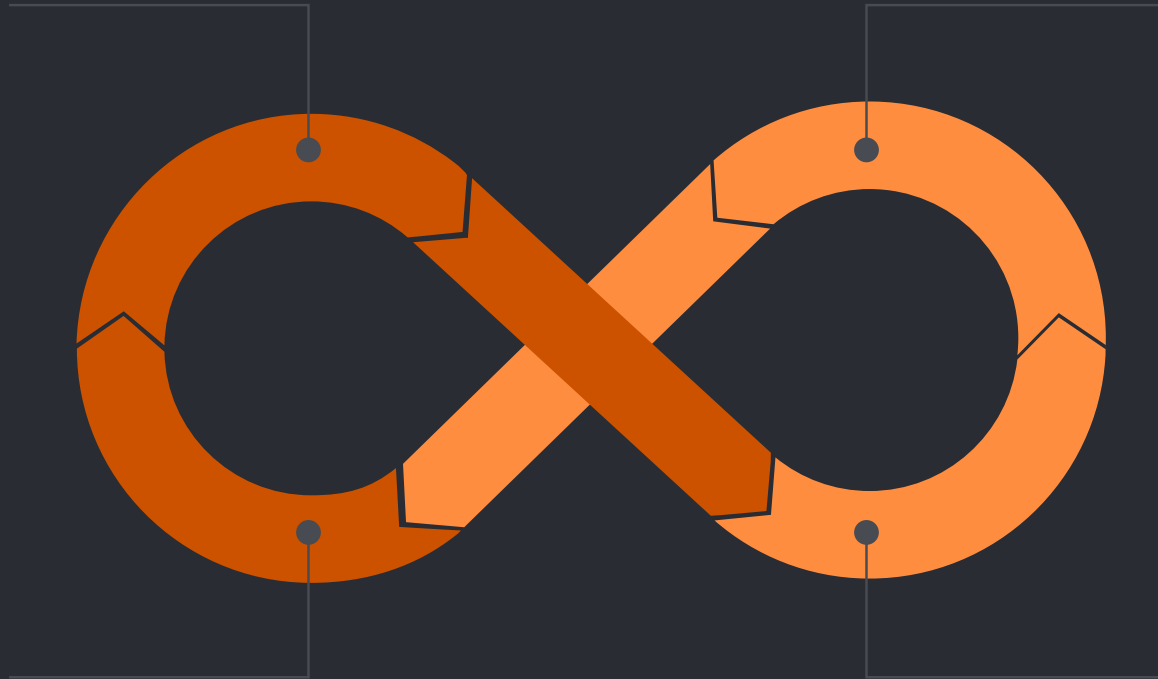
4

코드/명령 실행

CIA 삼요소 모두에 영향을 미치는 가장 심각한 유형 – 시스템에서 임의 코드를 실행할 수 있게 합니다.

취약점 관리란 무엇인가?

환경 내 알려진 취약점을 파악하고, 이를 해결하거나 완화하여 보안 상태를 개선하는 활동입니다.



이 과정은 한 번으로 끝나지 않습니다. 새로운 취약점이 계속 발견되므로 주기적으로 반복되어야 합니다.

데이터 수집



내부 데이터 수집

- 네트워크 매핑 도구(Nmap), CMDB를 통한 호스트 식별
- 취약점 스캐너: 네트워크 기반 스캔 또는 호스트 기반 에이전트
- 정기적 스캔과 스캐너 업데이트 필수 – 데이터는 매일 바뀝니다

외부 데이터 수집

- CVE, Exploit Database, Metasploit, CVE Details
- 위협 인텔리전스 피드 및 독점 데이터 소스
- 온라인 소스 또는 로컬 데이터 저장소 유지

데이터 분석: 컬링과 랭킹

컬링 (Culling) — 선별

각 취약점에 대해 '수용' 또는 '수용하지 않음' 이진 결정. 예: 특정 날짜 이후 발견, 알려진 익스플로잇 존재, 원격 공격 가능 여부 등을 기준으로 목록을 축소합니다.

랭킹 (Ranking) — 순위 지정

CVSS(1~10점 척도) 또는 자체 위험 지표를 사용해 취약점의 상대적 중요도를 정렬합니다. 컬링과 함께 사용하면 분석 속도와 정확도가 높아집니다.



컬랭크 실제 사례

클래스 C 네트워크(254개 주소) 스캔 결과: 84개 장치, 약 2,000개 취약점

2000

초기 취약점

84개 장치에서 발견된 총 취약점 수

500

컬링 후

CVSS 5 미만 제거 후 남은 취약점 (63개 장치)

38

고유 취약점

중복 제거 후 실제 검토 대상 — 목록 92% 축소

3

악용 가능

공개 익스플로잇이 있는 즉시 대응 필요 취약점

① 4개 호스트에 전체 취약점의 대부분이 집중되어 있었고, 악용 가능한 3개가 모두 포함되었습니다. 이 시스템들은 즉시 개선이 필요합니다.

권고 사항 제시 및 이행

권고 사항 제시

패치

취약점을 해결하는 공식 패치
적용

완화

방화벽 규칙, 설정 변경,
IDS/IPS 규칙 추가 등

권장 사항 이행 및 검증

- 시스템·애플리케이션 소유자와 구현 일정 합의
- 보안 위험과 권고 이유를 명확히 설명
- 이행 후 재스캔으로 변경 사항 검증
- 검증 완료 시 다시 데이터 수집 단계로 복귀

취약점 관리와 IT 위험 관리

취약점 관리는 기업 IT 위험 관리의 핵심 부분입니다. 효과적인 취약점 관리 없이는 IT 위험 관리 목표 달성이 어렵습니다.



취약점 관리의 각 단계는 IT 위험 관리 프레임워크의 단계에 직접 대응됩니다. 정기적인 취약점 데이터 수집은 자산 식별뿐만 아니라 통제의 효과성 모니터링에도 활용됩니다.

참고: NIST 800-53, ISO/IEC 27003, 27004, 27005

요약 및 다음 단계

01

CIA 삼요소 이해

기밀성, 무결성, 가용성을 기준으로 취약점을 분류하고 이해합니다.

02

수명 주기 운영

수집 → 분석 → 권고 → 이행 → 검증을 지속적으로 반복합니다.

03

컬랭크 활용

CVSS와 악용 가능성을 기준으로 취약점을 선별하고 우선순위를 정합니다.

04

위험 관리 통합

취약점 관리를 기업 IT 위험 관리 프레임워크와 연계하여 운영합니다.

다음 장에서는 취약점 관리 프로세스를 더 깊이 탐구하고, 자체 취약점 관리 시스템 구현 방법을 다룹니다.

